

# IT Department Standard Operating Procedures

SOP-IT-001-v3.2

|                     |                                       |
|---------------------|---------------------------------------|
| Document Reference: | SOP-IT-001-v3.2                       |
| Effective Date:     | January 1, 2026                       |
| Target Audience:    | Internal IT Staff & System Operations |
| Classification:     | Internal Use Only                     |

# 1. System Access & Security Operations

## 1.1 Authentication Mandates

All IT operations, administrative interfaces, and system access require mandatory Two-Factor Authentication (2FA) via hardware key or time-based OTP (TOTP). Single-factor authentication is strictly prohibited across all enterprise environments.

**Key Requirement:** Every system login, administrative console access, and privileged operation must be protected by a second authentication factor. Hardware security keys (FIDO2/U2F) are the preferred method; TOTP-based authenticator applications are acceptable where hardware keys are not feasible.

## 1.2 Network Enclosure

Remote administrative access is permitted only via corporate VPN. Direct public access to administrative portals, databases, or cloud dashboards is blocked at the perimeter firewall.

**Enforcement:** Firewall rules explicitly deny inbound connections on administrative ports (e.g., 22, 3389, 5432, 3306) from any non-VPN source IP range. All administrative traffic must traverse the encrypted corporate VPN tunnel.

## 1.3 Audit Logging

All administrative actions — including user provisioning, database schema updates, privilege escalation, and configuration changes — are captured in immutable audit logs (*audit\_logs* table). Logs are write-only (INSERT permitted, UPDATE/DELETE revoked) to ensure SOC 2 compliance.

**Compliance Note:** The *audit\_logs* table is configured with row-level security and append-only constraints. No user role, including database administrators, possesses UPDATE or DELETE privileges on this table. Log retention follows the organization's 7-year retention policy.

## 2. Environment Deployment Checklists

Prior to promoting code across environments, the following validation gates must be verified and signed off by the designated authority:

| Deployment Gate                | SIT Environment | UAT Environment                          | Production Environment                      |
|--------------------------------|-----------------|------------------------------------------|---------------------------------------------|
| Unit & Integration Tests       | Passed (100%)   | Passed (100%)                            | Passed (100%)                               |
| Security Scan (SAST / DAST)    | Standard scan   | High / Critical vulnerabilities resolved | <b>Zero Critical / High vulnerabilities</b> |
| Data Migration / Rollback Plan | Required        | Tested on staged data                    | Dry-run executed & verified                 |
| Approval Sign-off              | Team Lead       | Business Owner / QA Lead                 | <b>Head of IT or Deputy Head</b>            |

**Important: No code may be promoted to a higher environment until all gates for the target environment have been satisfied and documented. The approval sign-off must be captured in the change management system before deployment proceeds.**

## 3. Shift Management & Stale Heartbeat Protocols

### 3.1 Active Status Reporting

Duty engineers must maintain live statuses linked to an active Jira/Ticket ID and target environment (SIT / UAT / Staging / PROD). Recognized status values include:

- **Active** — Engineer is online and available for standard operations.
- **In Meeting** — Engineer is in a scheduled meeting but reachable for escalations.
- **On Call — Incidents** — Engineer is actively responding to or monitoring an incident.
- **Deployment Window** — Engineer is executing a planned deployment; standard requests may be deferred.
- **Out of Office** — Engineer is unavailable; deputy or on-call engineer assumes coverage.

### 3.2 Heartbeat Pulse

Active shifts require heartbeat updates at least once every 4 hours. The heartbeat signal confirms the engineer's continued availability and system connectivity. Heartbeat absence may indicate connectivity loss, system unavailability, or an unreported incident.

### 3.3 Stale Alert Handling

If no heartbeat is received within 4 hours during an active shift, the system auto-flags the engineer as **Stale / Verification Required**. The following automated actions are triggered:

- Team Leads are notified via real-time alerts (SMS, email, and in-app notification).
- The on-call escalation chain is activated if the stale status persists beyond 15 minutes.
- Incident continuity is verified to ensure no active incidents are left unattended.
- A post-shift review is scheduled to identify root cause (connectivity, human error, or system failure).

**Critical: The 4-hour heartbeat window is a hard requirement. Engineers on extended shifts or overnight rotations must ensure their heartbeat mechanism remains active for the full duration of their assigned shift.**

## 4. Emergency & Deputy Delegation Rules

### 4.1 Scheduled Activation

Deputy delegation rights for the **DEPUTY\_HEAD\_OF\_IT** trigger automatically based on scheduled leave entries of the Head of IT. The system reads the Head of IT's calendar / leave management record and activates deputy privileges at the start of the leave period.

**Scope of Deputy Authority:** While acting as deputy, the designated individual possesses the same approval, escalation, and decision-making authority as the Head of IT, including production deployment sign-off, incident escalation authority, and policy exception approvals.

### 4.2 Audit Lineage

All actions taken by a Deputy write directly to the compliance audit log with the flag *acted\_as\_deputy: true*. This ensures complete traceability and distinguishes deputy actions from primary role actions during compliance reviews and internal audits.

- Every approval, configuration change, and privileged operation is tagged with the deputy flag.
- Audit reports automatically segment deputy actions for leadership review.
- Deputy authority is revoked automatically when the Head of IT's leave period ends.

**Compliance Note:** Deputy actions are subject to the same audit standards and retention policies as all other administrative actions. The *acted\_as\_deputy* field is non-nullable and must be explicitly set to *true* or *false* for every audit log entry.

— End of Document —